IKB21403 – Vulnerability Analysis

Week 3: BlueMoon System Hacking

Practical Report / Walkthrough

Name: ELYNA FRANCESSCA LOH
Student ID: 52215251672

1. Introduction

This report documents my Week 3 practical for IKB21403 – Vulnerability Analysis using the VulnHub BlueMoon vulnerable machine. The task was to perform system hacking in a controlled lab environment and prepare a walkthrough/report.

The main goal was to understand the process instead of only getting the final flag. I started by identifying the target on the virtual network, checked the services that were running, enumerated the web application, found information that could be used to obtain access, and then worked through privilege escalation until root access was achieved.

All testing was performed against the BlueMoon virtual machine in my own lab environment.

2. Lab Environment

Attacker machine: Kali Linux (VirtualBox)
Target machine: BlueMoon 2021 (VulnHub)
Target IP identified during the lab: 10.0.2.3
Network: VirtualBox lab network (10.0.2.x)

The two virtual machines were connected to the same virtual network so that Kali could communicate with BlueMoon. I used the Kali terminal and browser for the enumeration and exploitation steps.

3. Objective

The Week 3 lecture material describes system hacking as a process that includes reconnaissance, scanning, gaining access, privilege escalation, maintaining access and clearing tracks. For this task, I focused on the practical BlueMoon machine and documented the main steps used to reach root.

The work was done only on the intentionally vulnerable machine provided for the exercise.

4. Reconnaissance

I first checked the network interface on Kali and used netdiscover to identify live hosts. Two relevant addresses appeared on the VirtualBox network, and the BlueMoon target was identified as 10.0.2.3.

This step was important because I did not want to assume the target address. I used the discovered address for the next scans.

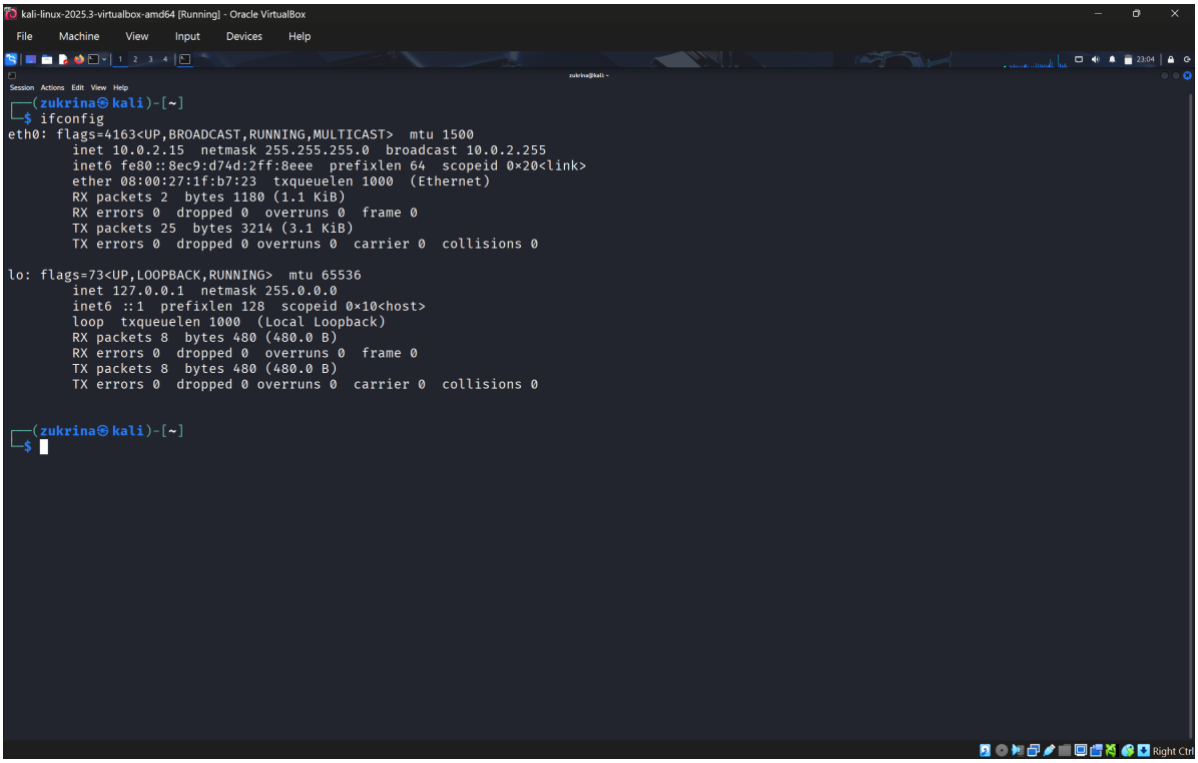


Figure 1. Netdiscover identified the BlueMoon target as 10.0.2.3 on the lab network.

5. Port and Service Scanning

After identifying the target, I used Nmap for service and version detection. The scan showed three important open TCP ports:

- 21/tcp – FTP (vsftpd 3.0.3)
- 22/tcp – SSH (OpenSSH 7.9p1)
- 80/tcp – HTTP (Apache httpd 2.4.38)

The HTTP service was titled BlueMoon:2021. These results gave me three possible areas to investigate: FTP for files, SSH for remote login, and HTTP for web enumeration.

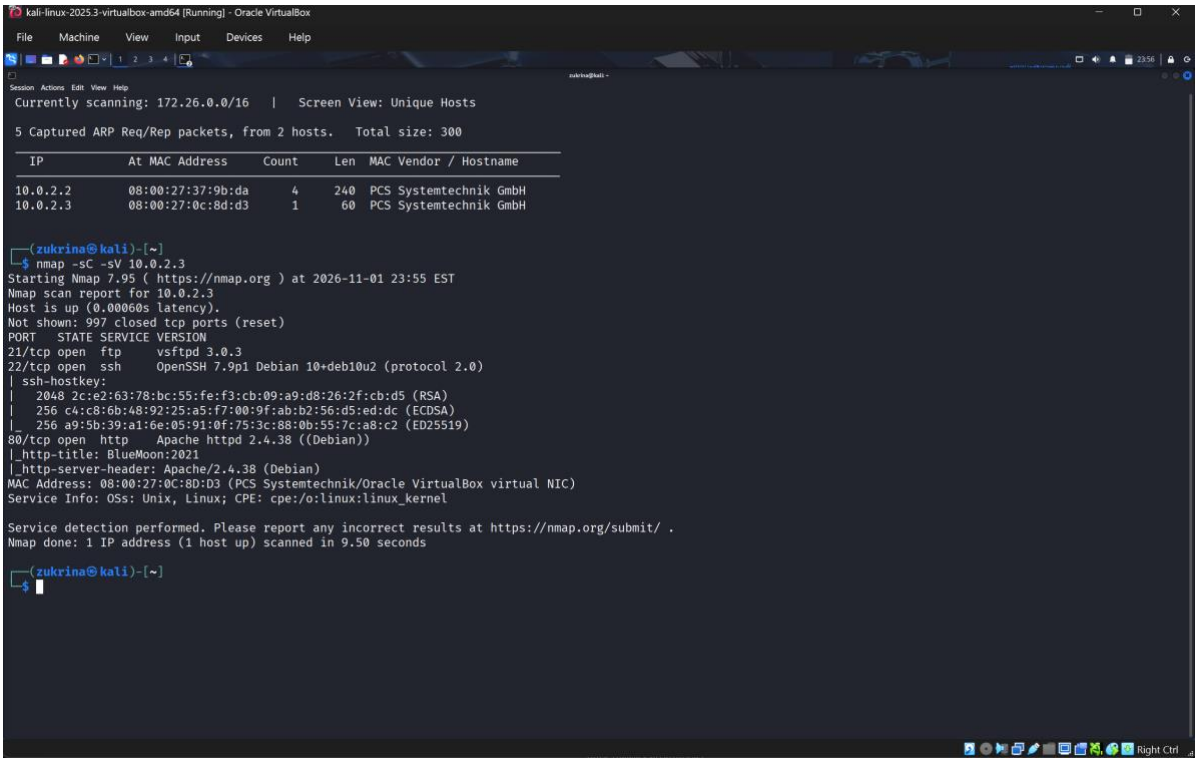


Figure 2. Nmap identified FTP, SSH and HTTP as open services.

6. Web Enumeration

I opened the target in the browser and confirmed that the web server was running. The main page was a simple BlueMoon page with the message that the game begins.

I then used Gobuster with the directory-list-2.3-small wordlist. The first scan did not immediately give a useful result, so I also checked the discovered hidden path directly. The /hidden_text page returned a maintenance-style page.

I inspected the HTML source of the page. The source contained a link to a hidden QR image named .QR_C0d3.png. I downloaded the image for further analysis.

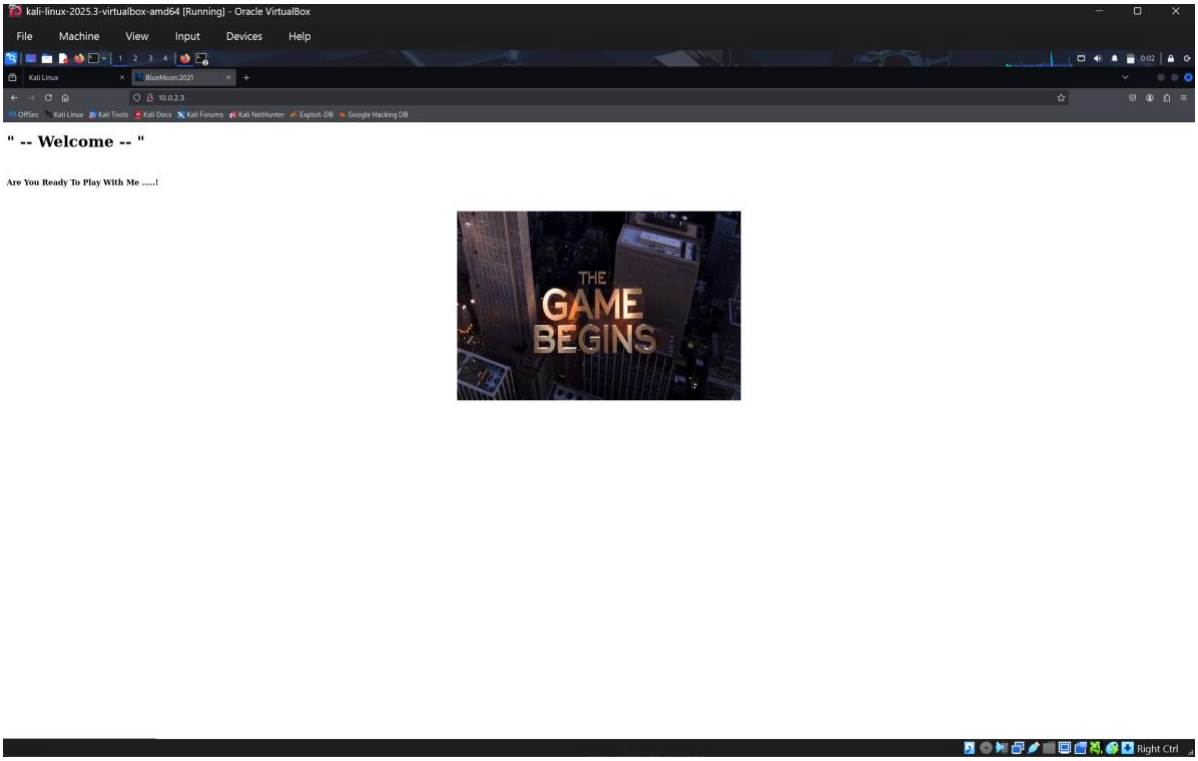


Figure 3. BlueMoon web page was reachable on port 80.

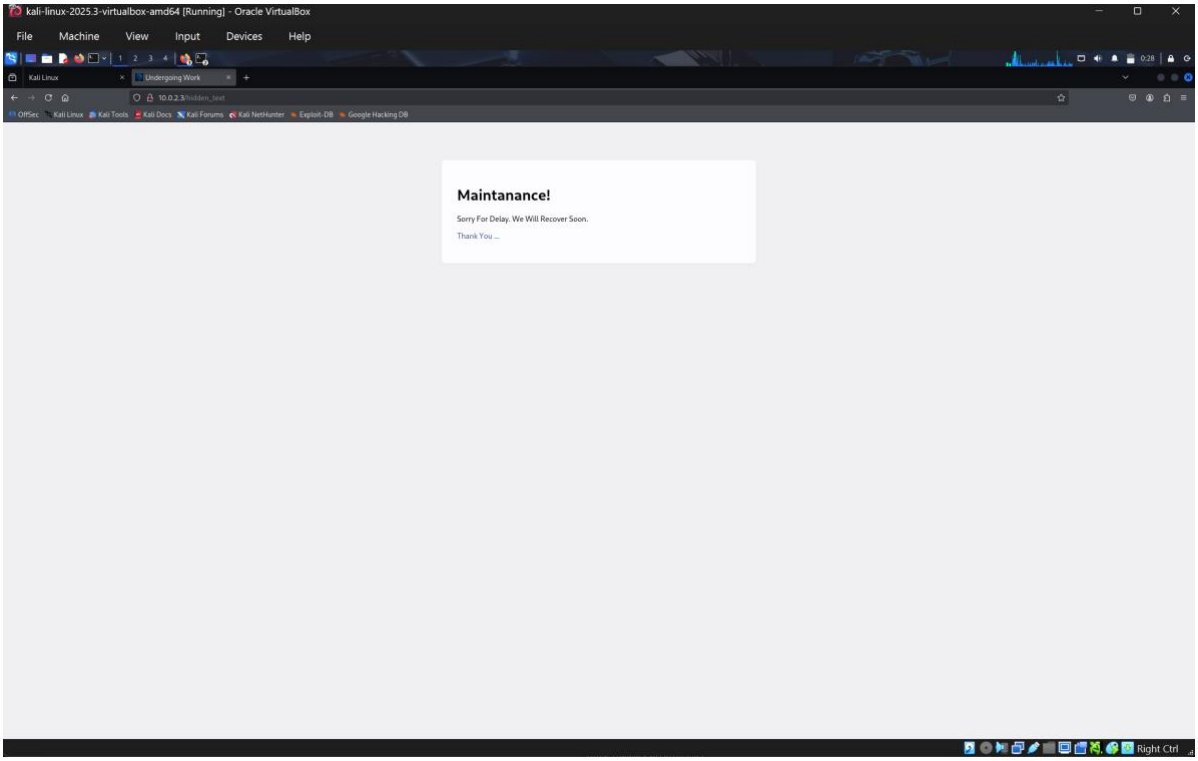


Figure 4. The hidden page returned a maintenance-style message.

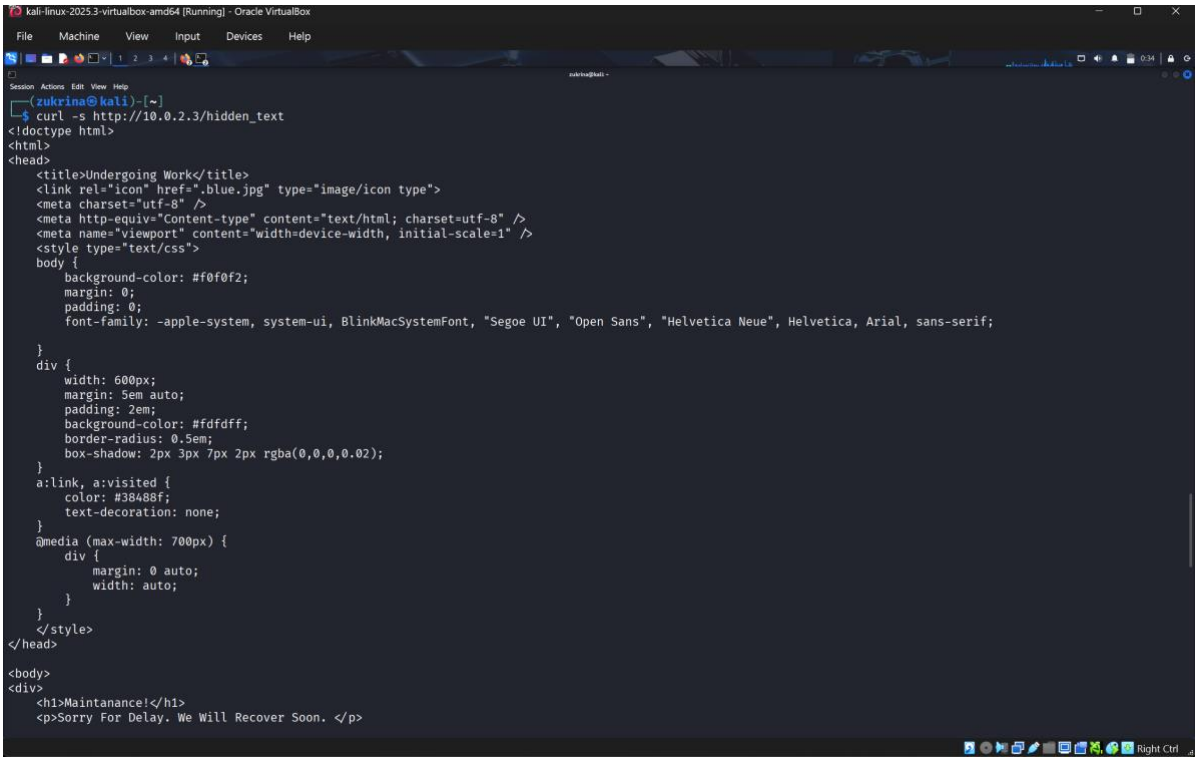


Figure 5. Inspecting the HTML source revealed the hidden QR image link.

7. QR Code and FTP Information

The QR image was opened and then decoded using zbarimg. I initially had a small problem because zbar-tools was not installed. After running apt update, I installed zbar-tools and repeated the decoding step.

The decoded QR content provided FTP connection information. I used that information to connect to the FTP service on BlueMoon. The FTP directory contained information.txt and p_lists.txt.

The information.txt file indicated that the account named robin had a weak password and pointed to the password list. I kept the actual credentials out of this public report/repository.

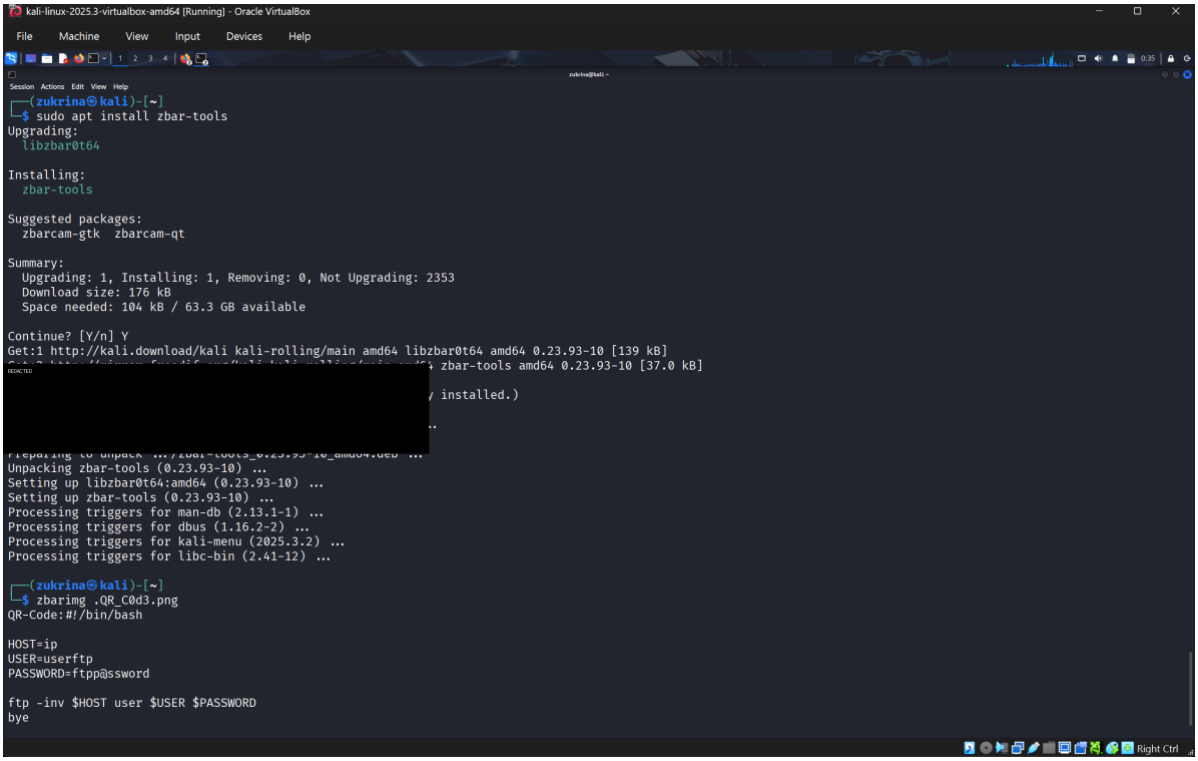


Figure 6. QR code decoding provided FTP connection information; sensitive values are redacted.

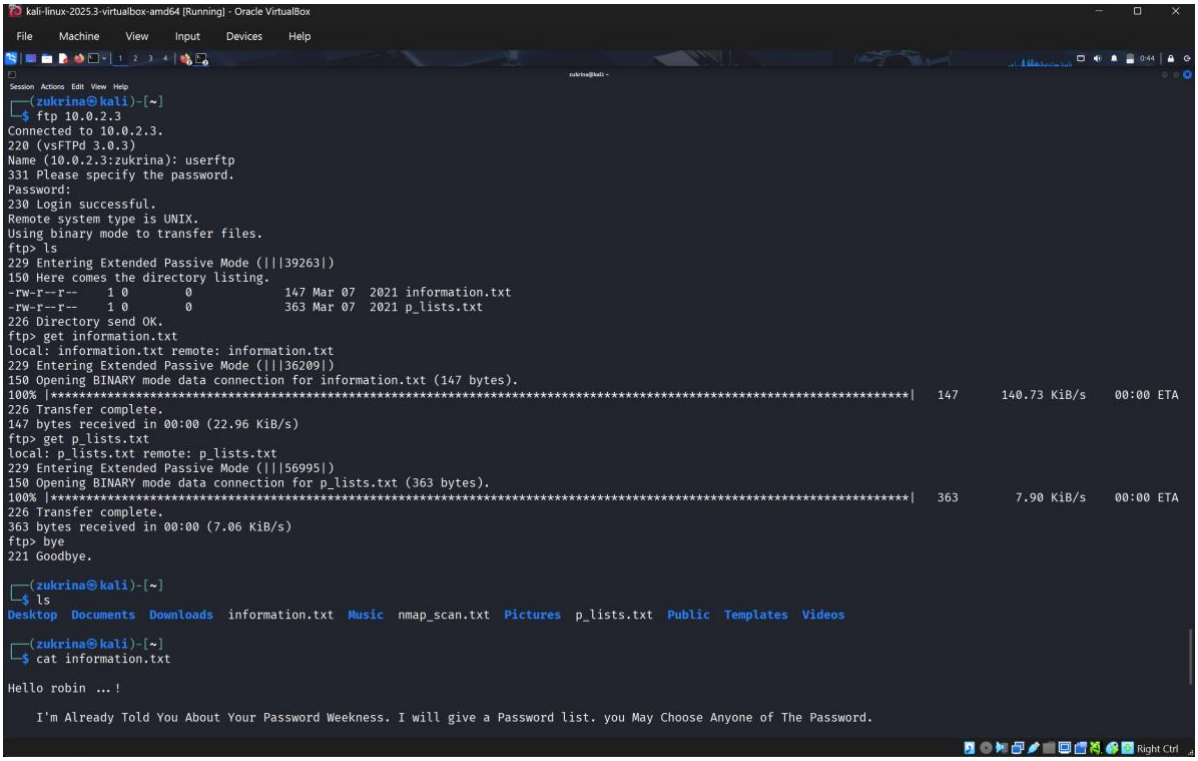


Figure 7. FTP access revealed information.txt and p_lists.txt.

8. SSH Access and User Flag

Using the password list obtained from the FTP service, I tested the SSH login for the robin account with Hydra. I made a small command-line typo during the first attempt by using -1 instead of -l, but corrected it and reran the command.

After obtaining valid credentials, I connected to BlueMoon using SSH as robin. I checked the home directory and found user1.txt. Reading the file confirmed that the first user-level flag had been obtained. The actual flag is redacted from this public version of the report.

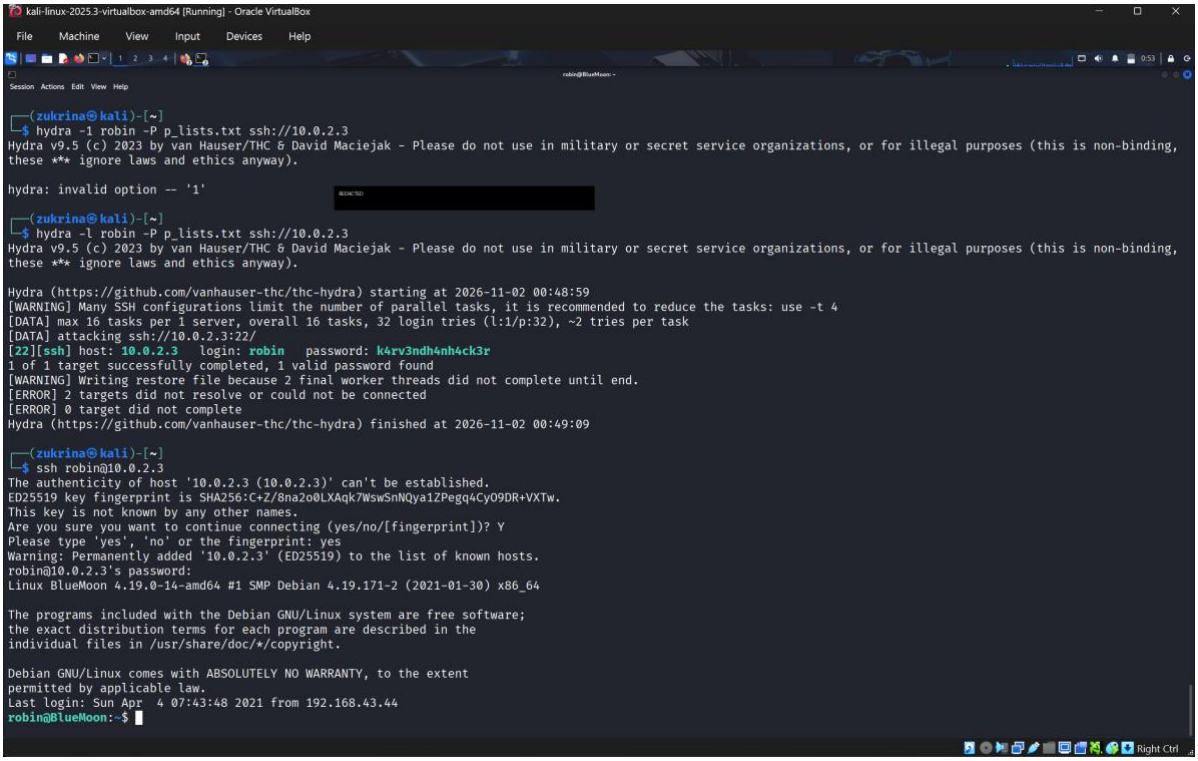


Figure 8. Hydra found a valid SSH login for robin; the password is redacted.

9. Privilege Escalation from Robin to Jerry

Once I had a shell as robin, I checked the sudo permissions using sudo -l. The result showed that robin could run /home/robin/project/feedback.sh as the user jerry without a password.

I inspected feedback.sh. The script asks for a name and feedback. Because the input was not safely handled, I tested the input with /bin/bash. This caused the script to execute a shell under the jerry account.

I confirmed the result by using whoami, which returned jerry.

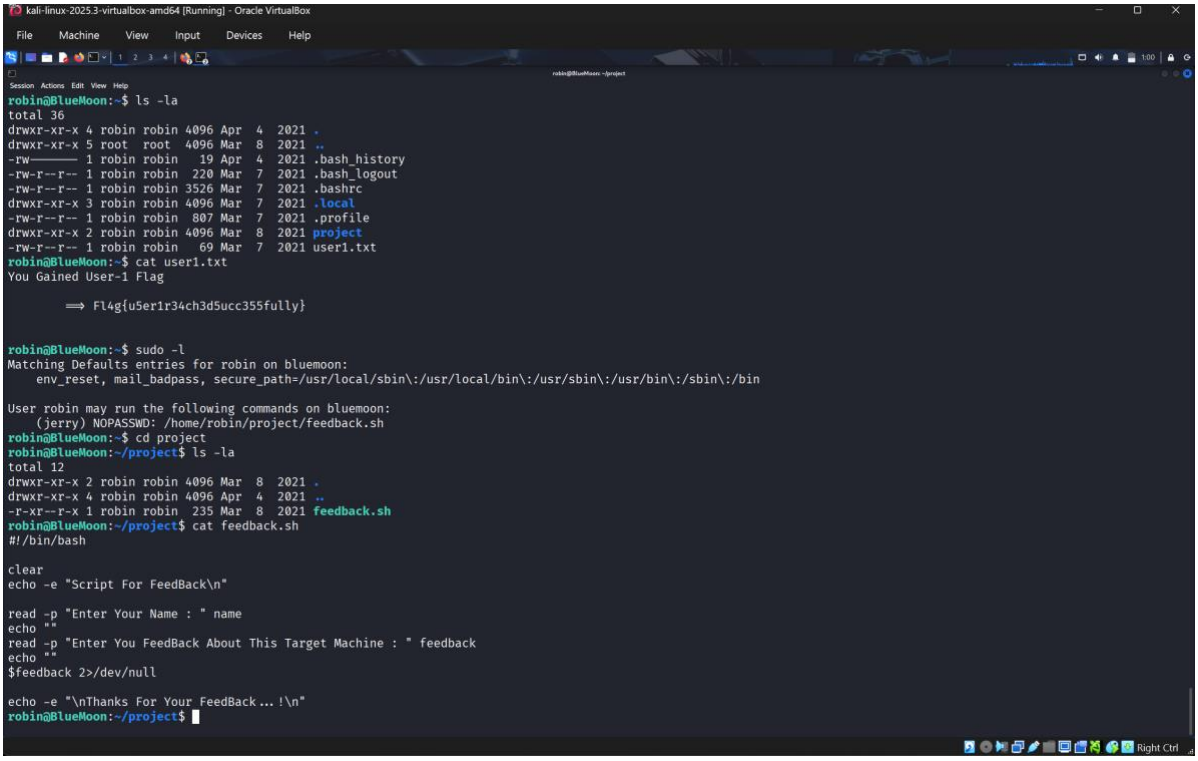


Figure 9. sudo -l showed that robin could run feedback.sh as jerry without a password.

10. Docker Group and Root Escalation

As jerry, I ran id and noticed that the account was a member of the docker group. In this vulnerable lab machine, that membership could be abused to access the host filesystem through a Docker container.

I used the Docker command shown in the lab walkthrough to mount the host filesystem and start a shell. After entering the container shell, whoami returned root and id confirmed UID 0.

I then moved to /root and listed the directory. The root.txt file was present, confirming that root access had been achieved. The root flag is redacted from the public report.

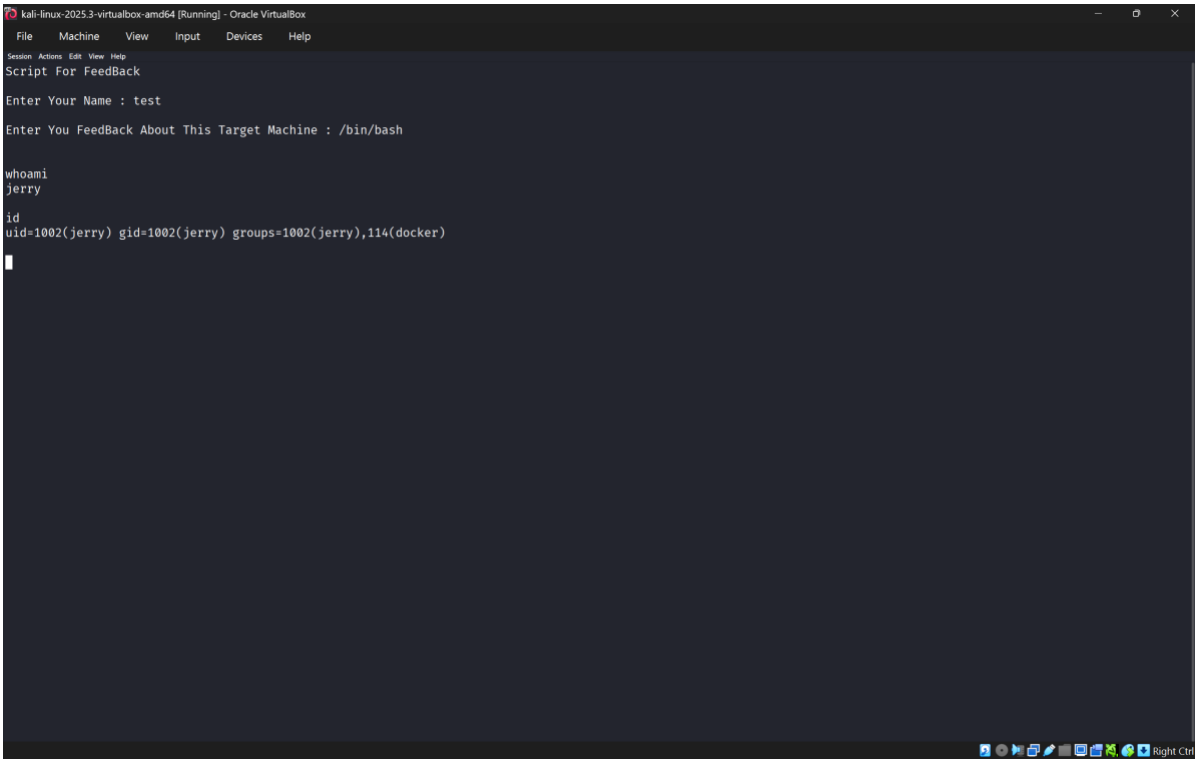


Figure 10. The jerry account was shown to be a member of the docker group.

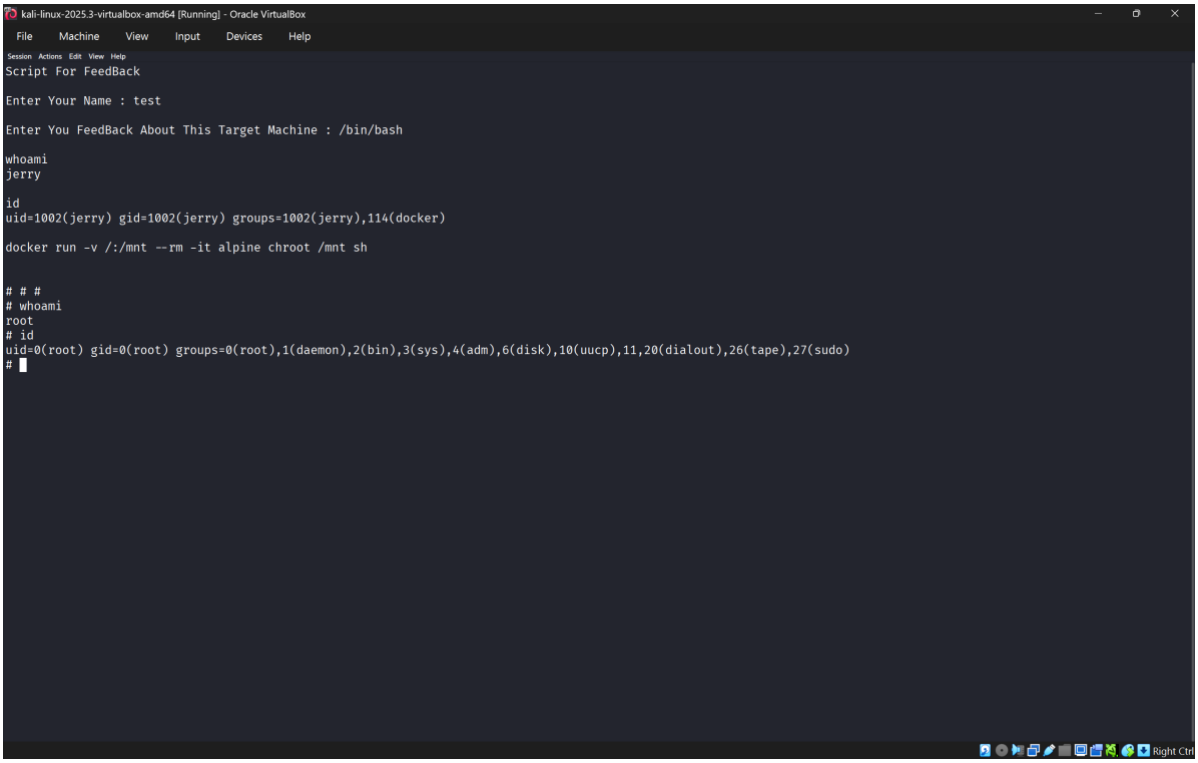


Figure 11. The Docker-based escalation resulted in a root shell.

11. Security Findings and Recommended Mitigations

The practical showed several weaknesses that would be important on a real system:

1. Exposed FTP service and sensitive files
   - Disable FTP if it is not required.
   - Use SFTP/SSH or FTPS when file transfer is required.
   - Do not store credentials or password lists in publicly reachable locations.

2. Weak/reusable passwords
   - Use long, unique passwords.
   - Add rate limiting and account lockout controls where appropriate.
   - Use MFA for important remote-access services.

3. Sensitive information hidden in a web page
   - Do not place credentials or secrets in HTML comments, hidden paths or downloadable files.
   - Apply proper authentication and authorization to sensitive resources.

4. Unsafe sudo permission
   - Do not allow a normal user to run an interactive or user-controlled script as another account without a password.
   - Restrict sudo rules to the minimum required command and validate all input.

5. Docker group privilege
   - Treat membership of the docker group as highly privileged.
   - Do not give untrusted users access to the Docker socket.
   - Consider rootless containers and stronger container isolation where suitable.

12. Conclusion

Overall, the BlueMoon lab helped me understand the full flow of a basic system-hacking exercise. The most useful part for me was seeing how different pieces of information connected together. The open web service led to a hidden resource, the hidden resource led to FTP information, the FTP files led to SSH access, and the local permissions eventually led to root access.

I also learned that small mistakes are normal during practical work. For example, I initially used the wrong Hydra option and had to install zbar-tools before I could decode the QR code. Fixing these issues and checking the output at every stage made the process easier to understand.

The exercise was completed in the intended controlled lab environment.

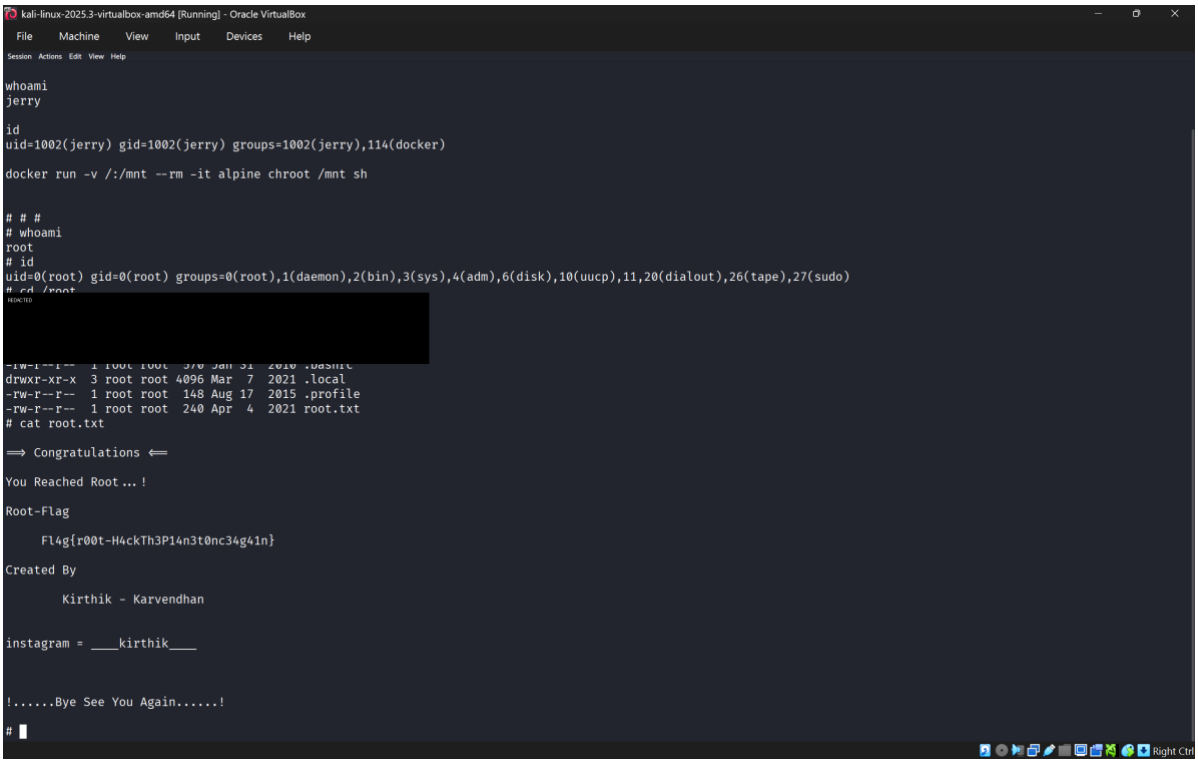


Figure 12. root.txt was reached successfully; the flag itself is redacted.

13. References

- IKB21403 Vulnerability Analysis – Week 3 lecture/task material: “Week3_26-29Oct”.
- VulnHub – BlueMoon (2021) vulnerable machine.
- Tools used during the lab: Nmap, Gobuster, zbarimg, FTP client, Hydra, SSH and Docker.